



LAPORAN

Rancang kebijakan proses autentikasi yang aman untuk aplikasi berbasis web

Bootcamp Cyber Security Batch 6

Disusun oleh: Ligar Alfath Rizqi

Mei 2026

1. Persyaratan teknis untuk password (panjang, kompleksitas, karakter khusus, dll.).

1.1 Panjang Password

1. Password minimal terdiri dari 12 karakter.
2. Sistem mendukung password hingga 64 karakter.
3. Pengguna dianjurkan menggunakan passphrase agar lebih mudah diingat namun tetap kuat.

1.2 Kompleksitas Password

Password harus mengandung kombinasi:

- Huruf besar (A-Z)
- Huruf kecil (a-z)
- Angka (0-9)
- Karakter khusus (!, @, #, \$, %, &, *)

Contoh password yang baik:

- AkuBelajarCyber2026!
- SecureLogin#Bootcamp

1.3 Larangan Password Lemah

Sistem harus menolak password yang:

- Menggunakan kata umum seperti "password123".
- Menggunakan informasi pribadi seperti nama atau tanggal lahir.
- Termasuk dalam database password bocor.
- Memiliki pola mudah ditebak seperti "12345678".

1.4 Penyimpanan Password

1. Password tidak boleh disimpan dalam bentuk plaintext.
2. Password harus di-hash menggunakan algoritma yang aman seperti:
 - bcrypt
 - Argon2
 - PBKDF2
3. Sistem harus menggunakan salt unik pada setiap password.

2. Aturan pengelolaan password (periode pergantian, penyimpanan aman, pencegahan penggunaan ulang).

2.1 Pergantian Password

1. Pengguna disarankan mengganti password setiap 90–180 hari.
2. Pergantian password wajib dilakukan jika terdapat indikasi kebocoran akun.
3. Sistem tidak boleh memaksa pergantian password terlalu sering tanpa alasan keamanan.

2.2 Pencegahan Penggunaan Ulang Password

1. Sistem menyimpan riwayat hash password sebelumnya.
2. Pengguna tidak boleh menggunakan kembali minimal 5 password terakhir.

2.3 Reset Password

1. Reset password dilakukan melalui email terverifikasi.
2. Link reset password memiliki masa berlaku maksimal 15 menit.
3. Token reset password hanya dapat digunakan satu kali.
4. Sistem harus menggunakan HTTPS saat proses reset password.

2.4 Pengamanan Session

2. Session ID harus bersifat unik dan sulit ditebak.
3. Session otomatis berakhir setelah 15–30 menit tidak aktif.
4. Cookie session harus menggunakan atribut:
 - a. HttpOnly
 - b. Secure
 - c. SameSite

3. Strategi mitigasi terhadap serangan seperti brute force, credential stuffing, dan phishing.

3.1 Mitigasi Brute Force Attack

Untuk mencegah brute force attack, sistem menerapkan:

1. Pembatasan percobaan login maksimal 5 kali.
2. Akun dikunci sementara selama 15 menit jika gagal login berulang.

3. CAPTCHA diterapkan setelah beberapa percobaan login gagal.
4. Logging aktivitas login mencurigakan.

3.2 Mitigasi Credential Stuffing

1. Sistem mendeteksi login abnormal dari IP atau lokasi berbeda.
2. Password dibandingkan dengan database password bocor.
3. Multi-Factor Authentication (MFA) diterapkan.
4. Rate limiting diterapkan pada endpoint login.

3.3 Mitigasi Phishing

1. Penggunaan HTTPS wajib pada seluruh halaman.
2. Pengguna diberikan edukasi keamanan terkait phishing.
3. Sistem mengirim notifikasi jika terdapat login dari perangkat baru.
4. Implementasi MFA untuk mengurangi risiko akun diambil alih.

4. Prosedur untuk autentikasi tambahan (contoh: Two-Factor Authentication).

4.1 Definisi

Two-Factor Authentication (2FA) adalah metode autentikasi tambahan yang meminta dua bentuk verifikasi identitas pengguna.

4.2 Metode 2FA

Metode yang dapat digunakan:

1. OTP melalui aplikasi authenticator.
2. OTP melalui email.
3. Security key atau biometrik.

4.3 Kebijakan Implementasi 2FA

5. 2FA wajib untuk akun administrator.
6. Pengguna biasa dianjurkan mengaktifkan 2FA.
7. Kode OTP memiliki masa berlaku maksimal 60 detik.
8. Backup code diberikan jika perangkat autentikasi hilang.

5. Penjelasan bagaimana kebijakan ini dapat diimplementasikan dalam aplikasi web.

5.1 Implementasi Backend

Pengembang dapat menerapkan:

- Hash password menggunakan bcrypt atau Argon2.
- Middleware rate limiting.
- Validasi input login.
- Session management yang aman.
- Penggunaan JWT dengan masa aktif terbatas.

Contoh implementasi sederhana menggunakan Node.js:

```
const bcrypt = require('bcrypt')
```

```
const password = 'SecurePassword123!'
```

```
const hashedPassword = await bcrypt.hash(password, 10)
```

5.2 Implementasi Frontend

1. Form login menggunakan HTTPS.
2. Password input menggunakan tipe “password”.
3. Validasi kekuatan password ditampilkan kepada pengguna.
4. Session timeout ditampilkan secara jelas.

5.3 Monitoring dan Logging

1. Sistem mencatat aktivitas login.
2. Admin dapat memantau login mencurigakan.
3. Log disimpan secara aman dan tidak boleh dimodifikasi sembarangan.